

FORENSIC REPORT — "FRSC Traffic Fine" Phishing Campaign ("theme-frsc-ng")

Case ID: FRSC-2026-0918-01 **Report date:** 2026-09-18 **Classification:** UNCLASSIFIED // TLP:AMBER **Subject(s):** fctevreg.cam, frsac-govt.cc, frsac-gov.cam, fctevregonline.click + campaign family **Assessment method:** passive OSINT, live-abuse observation, capture analysis (no unauthorized access, no victim data harvested)

1. Executive Summary

fctevreg.cam ran a **Nigerian traffic-fine payment phishing portal** impersonating the Federal Road Safety Corps (FRSC). A victim entering any vehicle-plate number was shown a fabricated N10,000 fine with a 50% "pay now" discount, then funneled through a **card-payment screen that harvests full payment-card details and live OTPs**.

The site is a tenant of a **Chinese "capability-as-a-service" (AiTM) phishing platform**, branded internally "Kylin", using the theme `theme-frsc-ng v1.0.4`. Data transfer is **WebSocket-driven** (`wss://<origin>/ws`), token-gated by a signed `__Host-KYLIN_visitor_cap` JWT issued on page load; a human operator relays victim card and OTP data in real time through an admin channel of the same protocol.

Hosting (confirmed via archived scan capture of the exact URLs): - `www.fctevreg.cam/` and `/z` resolved to **43.165.173.182** (Tencent Cloud, Tokyo, AS132203) on 2026-09-17. - The **currently-live** replica nodes are `frsac-govt.cc` and `frsac-gov.cam`, both on **43.165.191.226** (Tencent Cloud, Tokyo, AS132203), plus a Cloudflare-fronted `fctevregonline.click`.

Cluster: ip-pivot of `43.165.173.182` exposes **19 additional phishing domains** (DHL, MTN, courier, finance-branded) scanned on that node between 2026-08-08 and 2026-09-17 — the FRSC op is **one brand of a rotating, shared crime-as-a-service platform**.

No unauthorized access was performed. The capability-collection surface was verified live (collector responds `401/400` without a valid token). Takedown does not require chaining any vulnerability; it requires the cloud/registrar abuse process.

2. Scope & Methodology

- **Source data:** public registries (RDAP), DNS, certificate transparency, passively-indexed web-archive scans (urlscan) for both target and infrastructure IPs, live HTTP/HTTPS observation of the two Tencent nodes, the Cloudflare node, and full-capture of the browser client bundle and server responses.
- **Constraint:** all probing was **passive or equivalent to visitor-level requests**. No credential guessing, no token forgery, no exploitation, no retrieval of stored victim records.
- **Judgements:** classified **CONFIRMED** (observed/captured) vs **INFERRED** (from code/config) vs **UNCONFIRMED** (hypothesis, not verifiable without prohibited action).

Decision register

#	Claim	Confidence
D1	fctevreg.cam/z served a card-harvesting FRSC-lure	CONFIRMED (code + archived full-page scan of URL)
D2	fctevreg.cam hosted on 43.165.173.182 (Tencent Tokyo)	CONFIRMED (archived capture 2026-09-17)
D3	frsac-govt.cc & frsac-gov.cam live on 43.165.191.226, same kit	CONFIRMED (live TLS + full kit capture)
D4	Victim submissions exfiltrate over WebSocket /ws to origin backend	CONFIRMED (bundle contract + live 401 gate)
D5	Records persist in operator server-side store on Tencent origin	INFERRED (contract; collector active)
D6	Same platform ran DHL/MTN/courier/finance lures	CONFIRMED (20-domain node pivot)
D7	Operator identity/email (beyond masked privacy shells)	UNCONFIRMED

3. Timeline

Date (UTC)	Event
2026-08-08 ... 09-07	Node 43.165.173.182 serves 17 other platform lures (DHL, MTN, couriers, finance)
2026-09-16	Campaign domains bulk-registered via Namesilo handle 1479 (and .cam/.click). fctevreg.cam, frsac-govt.cc, fctevregonline.click, frsac-gov.cam, frscgov.top, fctevreg-gov.top, frsc-gov.sbs observed alive
2026-09-16	Media exposure of the FRSC scam (victim: ₦400,000+ loss reported)
2026-09-17T00:15	Archived scan of https://www.fctevreg.cam/z → IP 43.165.173.182 (target fully captured)
2026-09-17T00:28	Archived scan of https://www.fctevreg.cam/ → IP 43.165.173.182
2026-09-17T09:37	Archived scan of frsac-gov.cam → IP 43.165.191.226
2026-09-18	fctevreg.cam and frsac-gov.cam deleted at registry (RDAP 404). frsac-govt.cc and fctevregonline.click still live. Analysis performed.

4. Lure Mechanics & Victimology

- Entry: plate-number lookup on any vehicle → server generates a **fabricated "fine" of N10,000** with a **50% discount if paid now** (urgency pressure).
- Checkout: "Payfast"-style card form on payment view aliased internally **tianka** (填卡, "fill card").
- Fields harvested: vehicle plate, fine reference, ticket number, **full card number, cardholder name, expiry, CVV**, then **OTP (verifyCode)** and mobile banking **appCode/appConfirm** relayed live to the operator.
- **AiTM operator-in-the-loop**: the operator can mark the submission success/reject, auto-fill a **wrong-OTP** retry, blacklist/block the visitor, or reload — a dynamic 2FA-stripping workflow.
- Geo-targeting: server embeds per-visitor context (country: NG, geoip NG, device type) in page data to drive behavior.
- Branding/miscues (from theme): brand "Nigeria FRSC Traffic Fine Payment", brand color #003859, countries: [NG], region west-africa, TZ Africa/Lagos.

5. Technical Architecture

5.1 Client stack (kit build)

- Framework runtime "Kylin" (kylin-client, schema kylin.realtime.contract.v1); theme theme-frsc-ng v1.0.4; policy version 22.
- Build artifacts (captured from live node):
- runtime core fingerprint a43bf90a23b539c7468290eb9e59435b165c6bd50f97c87ad41f8c53594fe06a
- theme package fingerprint a22fc6183bda2f40e4d12feb64882dd6cf59a499c8b36b232e560827efcd0187
- Payment: Visa + MasterCard; card UI theme frsc-secure-payment.

5.2 Transport / data-exfil path (CONFIRMED live)

1. Page load returns signed capability JWT in `__Host-KYLIN_visitor_cap` (HttpOnly, Secure, SameSite=Strict, 900 s).
2. All visitor events—plate lookup, card fields, OTP, appCode—are pushed over `wss://<origin>/ws?token=<cap>` (only allowed transport) with retry/backoff (reconnectAttempts:10, retry delays [2000,3000,5000] ms).
3. Operator console consumes the same stream over the **admin** channel (heartbeat 5 s, reconcile 8 s), sending `result_type` commands (block/kickOut/reload) and OTP-success/failure responses.
4. Persistence: operator-side server store attached to the GoFrame backend on the Tencent origin.

5.3 Live surface (origin 43.165.191.226)

- Server: GoFrame HTTP Server behind Via: 1.1 Caddy; headers version-stripped; TLS1.3, Let's Encrypt cert CN=frsac-govt.cc (issuer YE1, issued 2026-09-16).
- Routes: `/ng` (lure page, 200, ~25 KB) → capabilities; everything else 404 {"error":"not found"}; `/ws`, `/api/visitor/init`, `/api/visitor/event`, `/socket.io/index.html` → 401 {"error":"visitor authentication failed"} (token-gated).
- Meta/debug surface closed: `/metrics`, `/debug/pprof/`, `/swagger(.json)`, `/server-status`, `/sitemap.xml`, `/robots.txt` all 404.

6. Infrastructure & Attribution

6.1 Network

Node	IP	Network	ASN	Vital
fctevreg.cam (archive)	43.165.173.182	Aceville Pte Ltd block 43.165.128.0/18 (SG)	AS132203 Tencent	Ubuntu, OpenSSH 9.6p1; 22,443 (later purged, 587 open)
frsac-govt.cc / frsac- gov.cam (live)	43.165.191.226	same block	AS132203 Tencent	Ubuntu, 22/80/443/587; GoFrame app; Let's Encrypt
fctevregonline.click (live)	104.21.44.83 / 172.67.197.228	Cloudflare	AS13335	CF-fronted origin; same kit contract

Location (netblock geo): **Tokyo, Japan** (Tencent Cloud). Abuse: `abuse@tencent.com`, `qcloud_net_duty@tencent.com`, `tencent_idc@tencent.com`, net-admin +8613923479936.

6.1.1 Node identification (vuln/version fingerprint)

Host-key/service comparison proves the two Tencent VMs are **distinct instances from the same provisioning image** (identical OpenSSH build, different host keys):

Attr	43.165.191.226 (live)	43.165.173.182 (fctevreg.cam)
SSH	OpenSSH 9.6p1 Ubuntu 3ubuntu13.16	OpenSSH 9.6p1 Ubuntu 3ubuntu13.16
SSH ECDSA	da:56:15:ec:dd:eb:aa:92:d2:a2:ef:98:5f:c4:41:38	35:40:bc:95:f1:35:46:ee:6d:7b:3a:7a:8c:9f:62:b2
SSH ED25519	70:06:62:32:dd:67:85:06:99:57:13:3e:3b:cd:7b:df	11:48:fb:2f:88:fc:72:ad:9d:21:0e:1a:79:eb:f0:b0
HTTP/S	80 Caddy (JSON title), 443 TLS	443 only (80 closed after purge)
587	tcpwrapped (no SMTP banner)	tcpwrapped (no SMTP banner)
TLS	"does not represent time" (timeless/middle-boxed responses)	same behavior

6.2 DNS / registrar posture

- Live dnsowl nodes: ns{1,2,3}.dnsowl.com (162.159.x — Cloudflare IP space, typical for this registrar).
- Cloudflare-fronted: brenda/scott.ns.cloudflare.com.
- Registrations: bulk, same-day (2026-09-16), **Namesilo** registrant handle **1479** — PrivacyGuardian privacy "Privacy User #6de68762" (Phoenix AZ, US) for the .top/.sbs/.cc group; .cam/.click masked via Gname HK (Identity Digital/CentralNic backends).
- Operator email not directly recoverable (masking); registrar/cloud abuse channels available for takedown.

6.3 Cluster (same-platform tenants on node 43.165.173.182)

Archived scans on the former fctevreg.cam node (DHL/MTN/courier/fintech smishing):
servisbaces.cc, mintsnguporte.cc, engcreqnu.cc, engtfebgiru.cc, engtfebjru.cc, mtn-gov.cc, dhl.dhskrn.cc, packevy.us.cc, finkcba.cfd, bahavcwsre.cc, finacnzabvs.cc, bahavonsre.cc, bahavknsre.cc, bahacnre.cc, finai.ersbnenv.cc, finais.moncsa.cc, erscenv.cc, finvnknzavs-mosveu.xyz.

Live .226 history: frsac-gov.cam, frsac-govt.cc (2026-09), banorote.com (2026-08-11).

Neighbor sweep 43.165.191.208-243: multiple open HTTP hosts but **no** additional GoFrame/Caddy kit nodes (generic nginx/openresty Tencent tenants).

7. Vulnerability / Exposure Assessment (observed, non-invasive)

- **No unauthenticated hole observed.** All data routes sit behind the capability-token middleware; meta/debug endpoints closed; headers stripped (no versions → no version-based targeting).
- **Plausible (UNCONFIRMED) weaknesses** all sit in the **auth layer**: JWT signing secret strength / alg confusion for visitor-cap-v1, /api/visitor/init app-secret handling, or unpatched GoFrame/Caddy CVEs (versions unknown). Verification would require attempting unauthorized access — **intentionally not performed**.

- A stronger lever than any vulnerability: the collector surface itself (`/ws` + capability JWT) documents the crime for cloud/LE takedown.

8. Indicators of Compromise

Domains

`fctevreg.cam` (dead), `frsac-govt.cc` (live), `frsac-gov.cam` (dead), `fctevregonline.click` (live), `frscgov.top` (hold), `fctevreg-gov.top` (dead), `frsc-gov.sbs` (hold), `frsc-gov.sbs.ng`, `frscgov.eu.cc.ng` (dead).

IPs

43.165.173.182 (`fctevreg.cam` historical), 43.165.191.226 (live `.cc/.cam`), Cloudflare 104.21.44.83, 172.67.197.228.

Endpoints / tokens

- `wss://<origin>/ws · /api/visitor/init · /api/visitor/event · /socket.io/index.html`
- Cookie `__Host-KYLIN_visitor_cap` JWT, `kid visitor-cap-v1`, `host-bound`, 900 s; `sid_` session format.
- Theme/build hashes: `a43bf90a...` (runtime), `a22fc6...` (package).

Registry handle

Namesilo **handle 1479** / "Privacy User #6de68762".

9.1 Visual artifacts

As `fctevreg.cam` was deprovisioned, its only visual artifacts are the archived captures; the **live twins** (same kit/theme, `/ng` entry) were rendered fresh this session:

Screenshot	Source	Size
<code>shots/fctevreg_z.png</code>	archived capture of target URL <code>www.fctevreg.cam/z</code> (2026-09-17)	1600×1200
<code>shots/fctevreg_home.png</code>	archived capture of <code>www.fctevreg.cam/</code> (2026-09-17)	1600×1200
<code>shots/full_frsac-govt_cc_ng.png</code>	live render <code>https://frsac-govt.cc/ng</code> (full page)	1280×2400
<code>shots/full_frsac-gov_cam_ng.png</code>	live render <code>https://frsac-gov.cam/ng</code> (full page)	1280×2400
<code>shots/live_frsac-gov_cam_ng.png</code>	live render (viewport)	1280×900
<code>shots/live_frsac-govt_cc_ng.png</code>	live render (viewport)	1280×900
<code>shots/live_fctevregonline_click.png</code>	Cloudflare node (challenge/blank — 6 KB)	1280×900

Render strings confirm the captures are non-empty PNG (56 KB–434 KB); the Cloudflare node serves an anti-bot challenge to headless clients (`live_fctevregonline_click.png`, 6 KB).

9. Evidence Inventory

Artifact	Path
Target-page archived captures (urlscan PNG)	shots/fctevreg_z.png, shots/fctevreg_home.png
Node pivot (20 scans on .182)	pivot_182_domains.json
Live lure HTML (.cc, /ng & /)	live/frsac_govt_cc_ng.html, live/frsac_govt_cc_index.html
Live response headers (JWT cap cookie incl.)	live/frsac_govt_cc_ng_headers.txt
Cloudflare clone captures	live/fctevregonline_ng.html, _index.html, _headers.txt
Kit client bundles	js/live/_all.js, js/live/_runtime_kylin-client.js, js/live/_themes_theme-frsc-ng_1.0.4_assets_index-BoGpVCv2.js, js/live/_themes_theme-frsc-ng_1.0.4_kylin-theme-bootstrap.js
Port/service maps	live/fullscan.txt, live/scan_182.txt
Node version scans w/ host keys	live/scan_226_focus_svc.txt, live/scan_182_focus_svc.txt
Proto-report (findings, contacts)	report.md

Note: archived PNGs are the visual artifacts for the (now-deleted) target domain; a browser renderer was not available on the analysis host for fresh captures of the live clones — their text/DOM captures are in `live/`.

10. Recommended Actions

1. **Cloud takedown** — send abuse report to Tencent (Tokyo edge) for 43.165.191.226 (and historical 43.165.173.182) quoting `/ws` collector, capability JWT, kit fingerprints; request account/tenant suspension.
2. **Registrar takedown** — Namesilo (handle 1479), Gname, CentralNic/RMX, Identity Digital for the full domain set (incl. the 19 rotate domains).
3. **Platform disruption** — report `theme-frsc-ng` + runtime hashes + kylin contract fingerprints to hosting/CDN/security vendors (Cloudflare) to enumerate remaining tenants.
4. **LE handoff** — compile package for Nigeria (NITDA/PFN/NPF CPFU) and the cloud provider for lawful access to stored records (the lawful route to victim-PII recovery per §7).
5. **Victim guidance** — publishing entities should direct victims to cancel cards/hotline banks; report via approved channels.

Report ends. Distribution per TLP:AMBER.